

Projet fil rouge — Auditer un SaaS de production & concevoir sa V2

Architecture IA · Année 5 NoCode / LowCode & IA · Épreuve finale

1. La mission

Vous êtes une société de conseil — seul ou avec un associé (donnez-lui un nom, c'est votre équipe). Un **client** vous confie une mission.

Votre client : KodeSaaS (Maxime Nicole), propriétaire d'eRezo — un SaaS de gestion de contacts et d'événements professionnels, construit vite, en vibecoding (développement piloté par IA).

Le client vous mandate pour **auditer son application** puis lui dire **comment reconstruire une V2 propre**. Sa demande est simple :

« Mon SaaS tourne, mais je ne sais pas s'il est **sûr**, ni s'il est **bien hébergé**, ni s'il est **bien construit**. Faites-moi un audit de ce qui existe, et surtout dites-moi comment il faudrait **architecturer, tester et sécuriser une V2** que d'autres pourraient reprendre. »

Votre livrable : un **rapport d'audit + recommandations pour la V2**, avec des propositions priorisées. Vous **ne codez rien** et vous **n'avez pas accès au code source** d'eRezo.

Deux postures, donc, à ne pas confondre :

- **L'audit de l'existant** se fait **de l'extérieur** (infrastructure + sécurité) : à partir du pentest et de ce que vous observez en production.
- **La conception de la V2** est un travail de **recommandations d'architecte** : vous ne jugez pas le code d'eRezo (vous ne l'avez pas), vous dites **quelles bonnes pratiques d'architecture, de tests et d'ingénierie** vous mettriez en œuvre pour bâtir une V2 solide.

Votre matière première :

- ce que vous découvrez pendant le **pentest** (les vraies failles d'eRezo) ;
- ce que vous **observez** de l'application et de son infrastructure en production (<https://erezo.fr>) : hébergement, HTTPS, en-têtes, configuration exposée... ;
- **le guide du module**, qui rassemble les bonnes pratiques d'architecture, de tests, d'infrastructure et de sécurité — c'est là que vous piochez pour vos recommandations V2.

On note votre **posture de conseil** et votre **raisonnement d'architecte** : diagnostiquer ce qui ne va pas, et proposer une manière propre de (re)construire.

2. Ce qu'on attend de vous

Votre rapport tient en **deux temps**.

Partie 1 — L'audit de l'existant : qu'est-ce qui ne va pas sur eRezo aujourd'hui ?

De l'extérieur, sans accès au code. À partir du pentest et de ce que vous observez.

a) Infrastructure

- Où et comment l'application est-elle **hébergée** ? (ce que vous arrivez à identifier : serveur, hébergeur, CDN...)
- Le site est-il en **HTTPS** ? Le certificat est-il correct ?
- Que révèlent les **en-têtes HTTP** et la **configuration** ? (en-têtes de sécurité présents ou absents, messages d'erreur trop bavards, fichiers ou pages qui ne devraient pas être exposés...)
- Voit-on des **traces de « fait vite »** : environnement de dev visible en prod, informations techniques qui fuient, etc. ?

b) Sécurité

- Les **failles** trouvées pendant le pentest, **priorisées** : **P0** (à corriger tout de suite) · **P1** (important) · **P2** (amélioration).
- Pour chaque faille : où elle se trouve, ce qu'elle permet, comment la corriger.

Partie 2 — Les recommandations pour la V2

Comment construire une V2 **bien architecturée, testée, bien hébergée et sécurisée**. Pour chaque thème, expliquez **la bonne pratique, pourquoi** elle compte, et **ce que vous recommandez concrètement** au client. C'est ici qu'on attend votre **raisonnement d'architecte** — et que vous **nommez et mobilisez explicitement les concepts du cours**.

A) Architecture & conception

- Comment **découperiez-vous le métier** d'eRezo en domaines clairs et bien délimités ?
- Comment **séparer le cœur métier de l'infrastructure**, pour qu'il ne dépende pas des détails techniques (base de données, framework, services externes) ?
- Comment garantir que le code **parle le langage du métier** ?
- Où placeriez-vous les frontières pour **limiter le couplage** et garder une base qui évolue sans tout casser ?

B) Qualité & tests

- Quelle **stratégie de tests** recommanderiez-vous pour la V2 ? Quels **types de tests**, et dans quelles proportions ?
- À quel **moment** écrire les tests dans le cycle de développement ?
- Que testeriez-vous **en priorité** (le cœur métier) et comment garantir une couverture crédible ?
- Quelle **intégration continue** et quelles conventions pour tenir la qualité dans la durée ?

C) Un projet fait pour l'IA & repreneable

- Comment outiller le dépôt pour un **développement assisté par IA** maîtrisé : **CLAUDE.md** / **AGENTS.md** (contexte et règles pour les agents), **Skills** (compétences réutilisables), **MCP** (connexion des agents aux outils et aux données) ?
- Quelle **documentation d'onboarding** (README, doc d'architecture) pour réussir le « **test du freelance** » — un dev externe comprend et lance le projet en moins de 30 minutes ?
- En quoi ces choix rendent la V2 **reprenable** et **durable** ?

D) Infrastructure, sécurité & données

- **Infrastructure propre** : bon hébergement, HTTPS partout, séparation des environnements (dev / production), sauvegardes.
- **Application sécurisée** : les grandes règles pour éviter précisément les failles trouvées en Partie 1 (contrôle des accès, en-têtes de sécurité, configuration, données exposées).
- **Mise en ligne maîtrisée** : un déploiement propre entre « ça marche sur mon poste » et « c'est en production ».
- **Respect des données des utilisateurs** : les règles de base sur les données personnelles.

Sur ces volets, on attend que **vous mobilisiez et nommiez vous-mêmes les bons concepts et outils** (architecture, tests, ingénierie assistée par IA). Un raisonnement qui « sent » les bons réflexes mais ne les nomme pas vaut moins qu'un raisonnement qui structure son analyse autour des bonnes notions.

3. Livrables & jalons

Quand	Livable
En séance	Pentest réalisé en classe — vous collectez les failles réelles d'eRezo (voir le protocole de pentest, obligatoire et à signer).
En fin de module	Rapport final (PDF) rendu — l'audit de l'existant (infra + sécurité) et les recommandations V2 (architecture, tests, ingénierie IA, infra, sécurité, données), au propre.

⚠ **Le pentest se fait uniquement en séance, en classe.** Aucun test sur eRezo hors du temps de classe. Le rapport final met au propre le travail réalisé en cours. **Anonymisez** toute donnée personnelle réelle croisée pendant les tests.

Format du rendu : un rapport clair de **6 à 10 pages**, adressé à votre client. Concis et concret vaut mieux que long et flou.

4. Comment vous êtes évalués (/20)

Volet	Points	Ce qu'on regarde
Audit sécurité (findings)	5	Vos failles sont réelles, bien décrites et priorisées P0/P1/P2. Vous savez reproduire une faille en direct.
Audit infrastructure	3	Votre lecture de l'hébergement, du HTTPS, des en-têtes et de la configuration est juste et bien expliquée.
V2 — Architecture & ingénierie	7	Vos recommandations d'architecture, de tests et d'ingénierie (outillage IA, repreneabilité) sont justes et argumentées , et vous mobilisez et nommez vous-mêmes les bons concepts . Vous défendez vos choix face aux questions.
V2 — Infra, sécurité & données	3	Vos recommandations infra / sécurité / données sont concrètes et actionnables , et répondent aux failles trouvées.
Restitution & posture conseil	2	Vous présentez clairement, vous vous adressez au client, vous structurez votre propos.
Bonus repreneabilité	+2	Verdict « test du freelance » argumenté : la V2 que vous décrivez serait-elle repreneable en < 30 min ? preuve à l'appui.

Un rapport **simple mais juste et bien nommé** vaut mieux qu'un rapport exhaustif et confus. On évalue votre **raisonnement d'architecte-conseil**, pas votre exhaustivité ni votre niveau technique brut.

5. Méthode : l'IA comme copilote

- Utilisez vos assistants IA pour **accélérer** votre travail — comprendre les failles, lire une configuration, structurer vos recommandations d'architecture, formuler clairement — mais **vérifiez toujours**. Une IA qui « invente » une faille inexistante, c'est un finding faux qui vous coûte des points.
- Étudiez le guide** du module : il couvre les bonnes pratiques d'architecture, de tests, d'infra et de sécurité de la Partie 2. C'est votre référence.
- Documentez votre méthode** (prompts, agents, outils, MCP utilisés) : la façon dont vous conduisez l'audit avec l'IA fait partie de la compétence évaluée — et illustre concrètement les notions CLAUDE.md / AGENTS.md / Skills / MCP.
- Pour la sécurité : **jamais de test sans cadre**. Vous ne lancez le pentest qu'après avoir lu et signé le protocole.

Bon audit. 🔍